

TRABAJO FIN DE MÁSTER

PDF Inspector & Signature Verifier

Auditoría técnica y forense de documentos PDF: firmas, sellos de tiempo, cadena de confianza y conformidad PDF/A en una sola llamada.

<https://vps-651608c6.vps.ovh.net/>

EL PROBLEMA

Un PDF firmado plantea cuatro preguntas

¿Está intacto?

La firma es válida y nadie ha tocado los bytes firmados ni añadido cambios después.

¿Quién firmó?

Datos del certificado del firmante y de su cadena de emisores.

¿Es de confianza?

La cadena llega a una raíz de confianza y el certificado no está revocado.

¿Cumple el formato?

Conformidad PDF/A-1b, estructura, cifrado y permisos del documento.

QUÉ INFORMA

Un informe JSON, sin guardar el documento

Integridad

Firma CMS/PAdES, cobertura de **/ByteRange** y cambios posteriores.

Sellos de tiempo

RFC 3161: imprint y firma de la TSA.

Cadena X.509

Validación PKIX contra un almacén de confianza configurable.

Revocación

OCSP y CRL, opcional y con tiempo máximo de 2 s.

PDF/A-1b

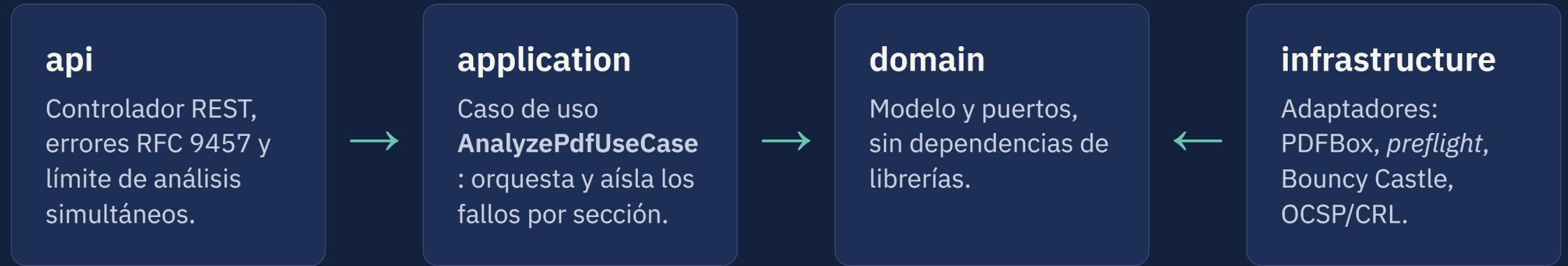
Validación formal con el módulo *preflight* de PDFBox.

Propiedades

Versión, páginas, rotación, dimensiones, cifrado y permisos.

ARQUITECTURA

Hexagonal, y comprobada por tests



El dominio no importa PDFBox ni Bouncy Castle: **ArchUnit** lo verifica en cada compilación.

INTEGRIDAD

Distingue tres situaciones tras firmar

Intacto

La firma cubre todo el documento y coincide con su resumen criptográfico.

Modificado después

Hay una actualización incremental posterior: la firma original sigue siendo válida, pero el documento cambió.

Manipulado

Los bytes firmados no coinciden con la firma, o el **/ByteRange** es hostil o inconsistente.

Con varias firmas, cada una se evalúa por separado. La integridad de la firma es independiente de la validez del certificado.

VEREDICTO

Una conclusión por firma, con sus motivos

Se combinan

Integridad de la firma

Cadena de confianza

Revocación (si se solicita)



Se obtiene

Válida: integridad y confianza correctas.

No admitida: no se puede dar por buena, con su motivo.

No válida: firma inválida o documento modificado.

Dos pantallas, sin frameworks

Validar

Arrastra un PDF de hasta 80 MB y obtén el informe con el veredicto por firma.

Casilla opcional para comprobar la revocación (OCSP/CRL).

Firmar

Firma PAdES con AutoFirma en el equipo del usuario.

La clave privada nunca sale de su equipo, y el resultado se valida con un clic.

HTML, CSS y JavaScript nativo. Tema claro y oscuro, cabecera CSP y sin CDNs.

STACK

Java 25 y librerías estándar del ecosistema

Área	Tecnología	Versión
Lenguaje	Java (LTS)	25
Framework	Spring Boot	4.1.1
Motor PDF y PDF/A	Apache PDFBox y preflight	3.0.8
Criptografía	Bouncy Castle	1.86
API	springdoc (Swagger UI)	3.1.1
Tests	JUnit 5, AssertJ, Mockito, ArchUnit	ArchUnit 1.5.1

CALIDAD

Cada cambio pasa por la integración continua

353

tests automáticos, incluidos los de arquitectura con ArchUnit.

GitHub Actions en cada *push*

1. Compila y ejecuta todos los tests (`./mvnw verify`).
2. Construye la imagen Docker y la arranca con los límites de producción.
3. Prueba de carga: 5 subidas simultáneas de ~79 MB, sin reinicios ni fallos por memoria.

DESPLIEGUE

Alojado en VPS

Contenedor endurecido

Imagen multi-etapa, usuario no root, sistema de ficheros de solo lectura, sin capacidades extra.

Límite de 2 GB y perfil de JVM con cada región de memoria acotada.

Servidor

OVHcloud VPS-1: 2 vCore, 4 GB, Ubuntu 24.04.

SSH solo con clave y cortafuegos con los puertos 22, 80 y 443.

HTTPS

Proxy Caddy con certificado de Let's Encrypt renovado automáticamente y cabecera HSTS.

La aplicación solo escucha en el bucle local.

MEDIDAS REALES

PDFs de hasta 80 MB, medidos en el servidor

5 de 5

subidas simultáneas de 83 MB
respondidas con éxito.

1013

MiB de memoria máxima,
sobre un límite de 2048.

0

reinicios, cortes por memoria y
errores de memoria en la JVM.

Un límite de dos análisis a la vez acota el consumo. Con un solo hueco y 5 s de espera, 3 de las 5 peticiones recibían un 503; con dos huecos y 30 s, ninguna.

Lo que hace y lo que queda fuera

Decisiones

Servicio sin estado: no guarda documentos ni datos de usuario.

La revocación solo se consulta para cadenas de confianza, con protección frente a SSRF.

El dominio no depende de ninguna librería.

Límites conocidos

Sin login: cualquiera con la URL puede usarlo, no es para documentos confidenciales.

Conformidad PDF/A-1b; otros perfiles no están cubiertos.

Subfiltros de firma admitidos: PKCS#7 y CAdES separados.

DEMOSTRACIÓN

Pruébalo con tu propio PDF

<https://vps-651608c6.vps.ovh.net/>

Código: <https://github.com/avalinani/verificador>

Licencia GNU GPL v3.0